



How resilient is your business to phishing?

Use this 16-point self-assessment to test your organisation's defences against phishing attacks. Each item represents a control aligned with NIS2 awareness requirements and real-world threats targeting SMEs in the EU. Score 1 point per box ticked.

1. Recognising phishing

- ☐ **Staff verify the sender's actual email address, not just the display name**
Phishing emails commonly spoof familiar names while using a completely different real address.
- ☐ **Unexpected urgency or pressure is treated as a red flag**
Phrases like 'act now' or 'urgent payment required' are classic warning signs.
- ☐ **Staff hover over links before clicking to verify the destination**
The real domain often differs from the displayed text — e.g. nordea-login.dk vs. nordea.dk.
- ☐ **We are cautious of unexpected attachments, even from known senders**
Compromised accounts are routinely used to send malware to existing contacts.

2. Email & account security

- ☐ **Multi-factor authentication is enabled on all email and business accounts**
Drastically reduces account takeover risk even if a password is phished.
- ☐ **SPF, DKIM, and DMARC are configured for our email domain**
Prevents attackers from spoofing your business domain in their phishing campaigns.
- ☐ **Look-alike domains are monitored or blocked at the email gateway**
Variants like soroflovv.com or soroflow-support.com — register and monitor them.



3. Employee awareness & training

- ☐ **Phishing awareness training is delivered at least once per year**
NIS2 Article 21 requires regular cybersecurity training for all staff and management.
- ☐ **Staff have a clear, easy way to report suspicious emails**
A 'Report Phishing' button, dedicated mailbox, or a named IT contact.
- ☐ **New employees receive phishing awareness training during onboarding**
Don't wait for the annual cycle — establish security awareness from day one.

4. Incident response

- ☐ **We have a written procedure for what to do if someone clicks a phishing link**
Speed matters: isolate the device, change passwords, notify IT, review activity logs.
- ☐ **Passwords can be reset and active sessions revoked quickly for compromised accounts**
Required to contain account takeover before further damage occurs.
- ☐ **Reported phishing attempts are logged and reviewed**
Patterns reveal targeted campaigns and inform future training topics.

5. Testing & continuous improvement

- ☐ **We run simulated phishing campaigns to test staff readiness**
NIS2 best practice — reveals real-world gaps before actual attackers do.
- ☐ **We track our click-rate over time and aim to reduce it**
A common goal: a click-rate under 5% within 12 months.
- ☐ **Staff are briefed on current threats targeting Danish SMEs**
MitID-spoofing, e-Boks impersonation, fake invoices from 'DSB' or 'PostNord'.

How did you score?

13–16	Strong defences	Book a call to refine your awareness programme
8–12	Notable gaps	Staff may be vulnerable, address soon
0–7	High exposure	Phishing is your most likely breach vector

Not sure where to start?

Book a free 20-minute intro call. We'll review your situation and tell you honestly what to do — no jargon, no obligation.

calendly.com/hello-soroflow/20min →

